

Simone Loga

Intro to Cybersecurity

Compliance Report

Cloud Services Security Incident Report

On July 6, 2024, Cloud Services experienced a confirmed cybersecurity incident involving unauthorized access to internal systems. The investigation revealed that an attacker originating from the IP address (192.168.10.15) conducted a coordinated attack which progressed from reconnaissance and network scanning to a brute-force series of attempts and ultimately successful compromise of multiple user accounts.

The attacker first performed reconnaissance by scanning for open services, including SSH and even some MySQL. This was followed by a targeted brute-force attack against the SSH service on server 10.0.0.12, as evidenced by the high volume of failed login attempts in the authentication logs. Eventually, the attacker successfully authenticated into multiple accounts, including administrative and standard user accounts, indicating either weak password policies or credential reuse across accounts.

Post-compromise activity suggests that the attacker maintained active sessions and may have executed commands or attempted lateral movement within the environment. Although the full extent of data access cannot be confirmed without deeper analysis of system logs, the presence of multiple compromised accounts significantly increases the risk of data exposure, system manipulation, and persistence mechanisms being established.

This incident highlights critical weaknesses in access control, monitoring, and system hardening. Immediate containment and long-term remediation actions are required to prevent further exploitation and reduce the risk of similar incidents in the future.

Analysis Process

The investigation began with a review of three primary log sources:

- **auth.log:** Used to analyze authentication attempts, including failed and successful logins
- **alerts.log:** Provided intrusion detection alerts from, highlighting suspicious network activity
- **audit.log:** Intended to track system-level actions such as file access and command execution

Initial analysis focused on identifying patterns in authentication activity, particularly failed login attempts and successful authentications. Command-line tools such as grep, awk, and sort are used to isolate suspicious behavior, including brute-force attempts and repeated access from a single IP address.

The alerts.log file was then examined to identify network-level indicators of compromise, such as port scanning and SSH probing. These findings were correlated with authentication logs to establish a timeline of attacker activity.

Finally, all findings were mapped to the MITRE ATT&CK framework to classify the attack techniques and better understand the progression of the incident.

Detailed Findings

1. Reconnaissance and Network Scanning

The earliest signs of malicious activity were identified in the alerts.log file at approximately 13:49. During this time, Suricata flagged multiple alerts indicating suspicious inbound traffic targeting the MySQL service (port 3306) on server 10.0.0.11.

Shortly thereafter, the attacker shifted focus to SSH services, as indicated by repeated “Potential SSH Scan” alerts targeting server 10.0.0.12 on port 22. These scans occurred consistently over a period of time, suggesting deliberate enumeration of available services and potential entry points.

All scanning activity originated from the same IP address, 192.168.10.15, indicating a single attacker or compromised host.

MITRE ATT&CK Mapping:

- Reconnaissance
- Discovery (T1046: Network Service Scanning)

2. Brute-Force Authentication Attempts

At approximately 14:28, the attacker began a brute-force attack against the SSH service. The auth.log file shows a rapid sequence of failed login attempts targeting the root account. These attempts occurred every few seconds, indicating the use of an automated script or tool.

Further analysis revealed over 700 invalid user attempts, suggesting that the attacker was attempting to identify valid usernames in addition to guessing passwords. This behavior is consistent with credential harvesting techniques.

The failed login attempts were concentrated within a short time window, demonstrating a high-frequency attack pattern typical of brute-force or dictionary attacks.

MITRE ATT&CK Mapping:

- Credential Access (T1110: Brute Force)

3. Successful Authentication and Initial Access

At 15:04, the attacker successfully logged into the system using the admin account. This marked the transition from attempted intrusion to confirmed compromise.

Following this initial success, the attacker gained access to multiple additional accounts, including:

- john
- kathy
- bill (multiple sessions)
- james
- hank

All successful logins originated from the same IP address (192.168.10.15) within a short timeframe. This pattern strongly suggests that the attacker had access to a list of valid credentials, either through password reuse, weak passwords, or prior credential compromise.

The rapid succession of successful logins across different accounts indicates that the attacker was systematically accessing available accounts rather than targeting a single user.

MITRE ATT&CK Mapping:

- Initial Access (T1078: Valid Accounts)

4. Post-Compromise Activity

Following successful authentication, the alerts.log file shows continued suspicious activity involving SSH connections. Specifically, multiple alerts were generated indicating “invalid ack” packets during active sessions between the attacker’s IP and the target server.

These alerts occurred around 15:19 and suggest abnormal session behavior, which may indicate:

- Execution of remote commands
- Automated scripts interacting with the system
- Attempts to maintain persistence or escalate privileges

Additionally, the presence of repeated connections to the same service suggests that the attacker remained active within the environment after gaining access.

MITRE ATT&CK Mapping:

- Execution
- Lateral Movement (T1021: Remote Services)

Conclusion and Hypothesis

Based on the evidence collected, Cloud Services experienced a confirmed security breach. The attack followed a clear progression beginning with reconnaissance, followed by targeted scanning, brute-force credential attacks, and ultimately successful compromise of multiple user accounts.

The use of a single IP address throughout the attack indicates a coordinated effort rather than random or unrelated events. The attacker demonstrated persistence and methodical behavior, first identifying vulnerable services, then exploiting weak authentication mechanisms to gain access.

The successful compromise of multiple accounts suggests systemic weaknesses in password security, such as weak passwords, lack of multi-factor authentication, or absence of account lockout policies. Once access was obtained, the attacker likely performed additional actions within the system, although the full scope of these actions requires further investigation of audit logs.

Overall, the incident represents a significant security failure with potential implications for data confidentiality, system integrity, and operational continuity.

Recommendations for making solutions to prevent future incidents:

Short-Term (24–48 Hours)

- Immediately isolate affected systems from the network
- Disable compromised user accounts
- Force password resets for all users
- Block the attacking IP address -192.168.10.15

- Review active sessions and terminate unauthorized connections

Medium-Term (1–4 Weeks)

- Implement account lockout policies to prevent brute-force attacks
- Enforce strong password requirements
- Enable multi-factor authentication for all users
- Harden SSH configurations
- Conduct a full audit of user accounts and permissions

Long-Term (1–6 Months)

- Deploy centralized log monitoring and SIEM solutions
- Implement intrusion prevention systems in addition to IDS
- Conduct regular security training for employees
- Perform periodic penetration testing and vulnerability assessments
- Align security practices with established frameworks such as NIST or CIS Controls

Areas for Further Investigation

- Analyze audit.log to determine whether files were accessed, modified, or exfiltrated
- Identify whether privilege escalation occurred after initial access
- Determine if malware or persistence mechanisms were installed
- Investigate whether other systems within the network were compromised
- Assess whether sensitive customer or business data was exposed

AI Usage

I used AI to help me recognize different patterns in the breach. Another way it was used was to convert the timestamps into a readable format.